

ACME CORPORATION - INCIDENT RESPONSE POLICY

Version 1.4 | Effective Date: February 15, 2025

SECTION 1: PURPOSE AND SCOPE

This policy establishes the framework for detecting, reporting, and responding to security incidents at ACME Corporation. It applies to all employees, contractors, and managed service providers operating on behalf of ACME.

SECTION 2: INCIDENT CLASSIFICATION

Incidents are classified into four severity levels:

- P1 (Critical): Active breach, ransomware, or data exfiltration in progress. Response required within 15 minutes. CISO and executive team must be notified.
- P2 (High): Confirmed compromise of a system or account with potential data exposure. Response required within 1 hour. IT Security manager must be notified.
- P3 (Medium): Suspicious activity detected but not yet confirmed as a breach. Response required within 4 hours. Security analyst on call must be notified.
- P4 (Low): Policy violation or anomalous activity with no immediate threat. Response required within 24 hours. Standard ticket workflow applies.

SECTION 3: REPORTING REQUIREMENTS

All suspected security incidents must be reported immediately to the Security Operations Center (SOC) by emailing security@acme.com or calling the 24/7 hotline at ext. 9911. Employees must not attempt to investigate or remediate incidents themselves. Delaying the reporting of a known incident is a policy violation and may result in disciplinary action.

SECTION 4: INCIDENT RESPONSE PHASES

Phase 1 - Identification: Confirm and classify the incident. Assign an Incident Commander.
Phase 2 - Containment: Isolate affected systems to prevent further spread. Preserve forensic evidence before any remediation. Short-term containment must begin within 30 minutes of P1 confirmation.
Phase 3 - Eradication: Remove the root cause (malware, compromised credentials, etc.). All affected systems must be rebuilt from known-good images, not patched in place.
Phase 4 - Recovery: Restore services from clean backups. Monitor restored systems intensively for 72 hours post-recovery.
Phase 5 - Post-Incident Review: A written post-mortem must be completed within 5 business days of incident closure. Root cause, timeline, and corrective actions must be documented.

SECTION 5: EVIDENCE PRESERVATION

Forensic images of affected systems must be taken before any remediation activity. Logs must be exported and preserved in write-once storage (AWS S3 with Object Lock). Chain of custody documentation must be maintained for all evidence. Evidence must be retained for a minimum of 3 years or the duration of any legal proceedings, whichever is longer.

SECTION 6: REGULATORY NOTIFICATION

If a data breach involves personal data of EU residents, the relevant supervisory authority must be notified within 72 hours of discovery under GDPR Article 33. If a breach affects customers, affected individuals must be notified within 30 days in accordance with applicable state breach notification laws. The Legal and Compliance team must be engaged immediately for any P1 or P2 incident.

SECTION 7: TESTING AND TRAINING

The incident response plan must be tested at least annually via a tabletop exercise.

A full red team simulation must be conducted every 2 years. All employees must complete incident response awareness training annually. The SOC team must complete hands-on incident response training every 6 months.

SECTION 8: POLICY MAINTENANCE

This policy must be reviewed and updated at least annually or following any major incident. The CISO is responsible for approving all updates to this policy.